Information security incident management policy



© 2018 Al-Nafi. All Rights Reserved. 1

We will cover this topic in a very detailed manner in Incident Response a hands on approach, along with ISO 27001 and PCI DSS courses. So do not worry about any reference mentioned here as they will be discussed at a later stage. For now you should understand what is information security incident management and what stages are involved in the process.

Information security incident management policy

An organization information security incident management policy should provide the formally documented principles and intentions used to direct decision-making and ensure consistent and appropriate implementation of processes, procedures, etc. with regard to this policy.

Any information security incident management policy should be part of the information security strategy for an organization. It should also support the existing mission of its parent organization and be in line with already existing policies and procedures.

An organization should implement an information security incident management policy that outlines the processes, responsible persons, authority and reporting lines (specifically the primary point of contact for reporting suspected incidents) when an information security incident occurs. The policy should be reviewed regularly to ensure it reflects the latest organizational structure, processes, and technology that can affect incident response. The policy should also outline any awareness and training initiatives within the organization that is related to incident response.

Involved Parties in Incident Response Management



© 2018 Al-Nafi. All Rights Reserved. 2

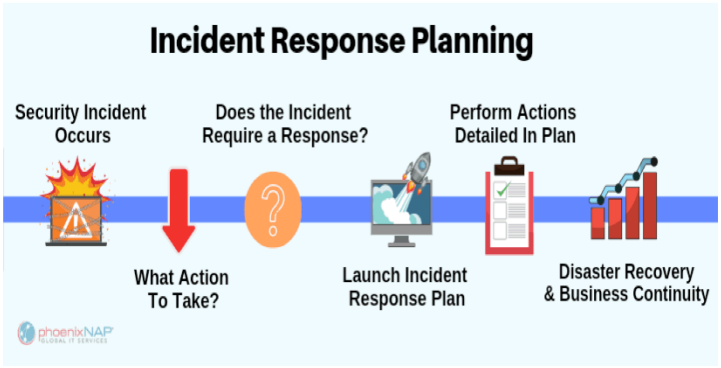
Involved parties

A successful information security incident management policy should be created and implemented as an enterprise-wide process. To that end, all stakeholders or their representatives should be involved in the development of the policy from the initial planning stages through the implementation of any process or response team. This may include legal advisors, public relations and marketing staff, departmental managers, security staff, system and network administrators, ICT staff, helpdesk staff, upper-level management, and, in some cases, even facilities staff.

An organization should ensure that its information security incident management policy is approved by a member of top management, with commitment from all of top management.

Ensuring continued management commitment is vital for the acceptance of a structured approach to information security incident management. Personnel need to recognize an incident, know what to do and understand the benefits of the approach by the organization. Management needs to be supportive of the information security incident policy to ensure that the organization commits to resourcing and maintaining an incident response capability. The information security incident management policy should be made available to every employee and contractor and should also be addressed in information security awareness briefings and training.

Information Security incident management plan



© 2018 Al-Nafi. All Rights Reserved. 3

Information security incident management plan

The aim of an information security incident management plan is to document the activities and procedures for dealing with information security events, incidents and vulnerabilities, and communication of them. The plan stems from and is based on the information security incident management policy.

Overall, the plan documentation should encompass multiple documents including the forms, procedures, organizational elements and support tools for the detection and reporting of, assessment and decision making related to, responses to and learning lessons from information security incidents.

The plan may include a high level outline of the basic flow of incident management activities to provide structure and pointers to the various detailed components of the plan. These components will provide the step-by-step instructions for incident handlers to follow using specific tools, following specific workflows or handling specific types of incidents based on the situation.

The information security incident management plan comes into effect whenever an information security event is detected or information security vulnerability is reported.

An organization should use the plan as a guide for the following:

a) responding to information security events;

b) determining whether information security events become information security incidents;

c) managing information security incidents to conclusion;

d) responding to information security vulnerabilities;

Information security incident management key stages

- Detection
- Response
- Mitigation
- Reporting
- Recovery
- Remediation
- Lessons learned



© 2018 Al-Nafi. All Rights Reserved. 4

The key stages of Information Security Incident Management are:

- Detection
- Response
- Mitigation
- Reporting
- Recovery
- Remediation
- Lessons learned

Detection

This is the first step in incident management. You must be able to discover if the incident really happened or have taken place or not. You may have to deal with various false positives or other issues along the way.

You can use the following solutions as part of the detection phase:

- Intrusion detection systems (IDSs)/intrusion prevention systems (IPSs)
- Anti-malware solutions
- Log analysis
- Firewalls
- Vulnerability scan results

Administrative



© 2018 Al-Nafi. All Rights Reserved.

Administrative investigations are conducted usually once the incident is the result of insider activity from a malicious or disgruntled employee. In such cases, organization involves the HR, Legal and other relevant departments to take appropriate action as per the legal, statutory and regulatory requirements.

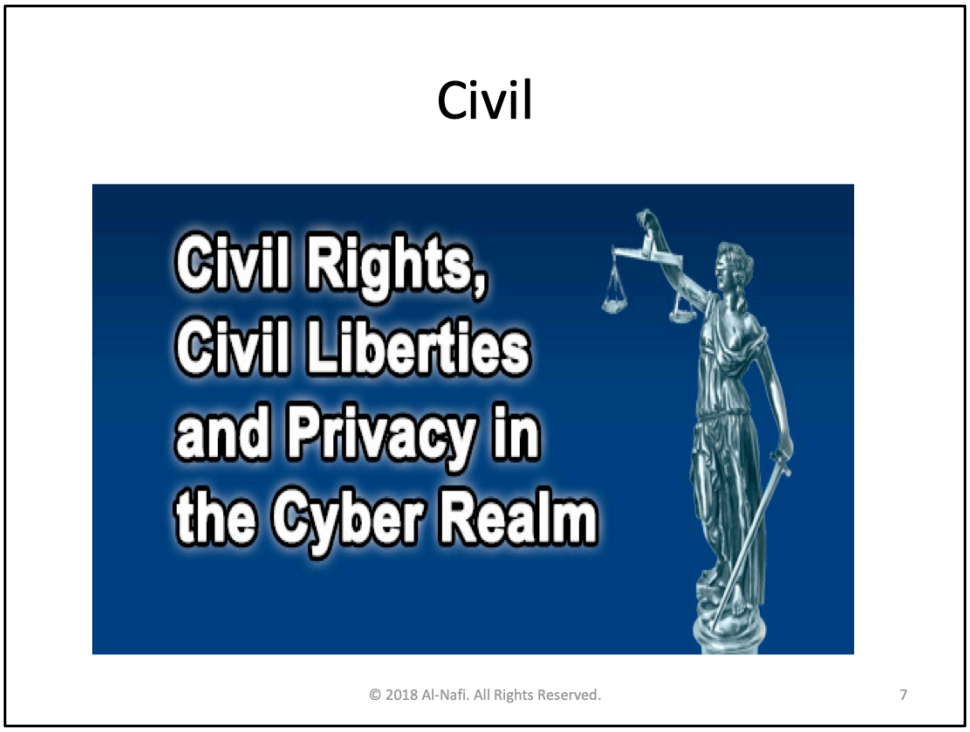
Criminal



© 2018 Al-Nafi. All Rights Reserved.

Depending on what kind of crime took place, for example if the crime impacted the organization internally only and not its customers or externally where its customers data was compromised; appropriate criminal incident classification and actions are taken place. That classification determines if outside authorities i.e. police, law enforcements, and or relevant security services are required to be involved or not.

When law enforcement conducts the investigation, the organization may or may not be involved in the process; this is the option of the law enforcement body. In many jurisdictions, law enforcement may request the organization to voluntarily collect or disclose information about the situation to further the investigation and build a case. Typically, the organization may opt to participate or not participate in an investigation when informally requested to do so. However, if the law enforcement entity acquires a warrant or subpoena, which are governmental/judicial orders to disclose information, then the organization must comply with
the request to the fullest extent required. Any interference or negligence on the part of the organization in fulfilling mandated requests may actually constitute additional crimes: obstruction of justice, contempt of court, interfering with an investigation, and so forth.



Unlike criminal proceedings, a civil dispute involves a court but not a prosecutor. An investigation with the intended purpose of a lawsuit should involve the same degree of documentation and adherence to detail as a criminal investigation, because the organization will not be deciding the outcome but will be trusting the court to determine if either party owes restitution to the other.

Some incidents may involve components of both criminal and civil actions; for instance, if the organization is hacked by a malicious attacker, the hack itself might be a criminal act (violating the law), and it might also cause damages for which the victim organization can sue the attacker. In these situations, the parties to the civil suit can often use the evidence collected during the criminal proceedings to support their claims. However, civil courts usually
also allow a greater breadth of evidence that may be presented in a more liberal fashion than in a criminal case—some of the restrictions placed on law enforcement when collecting evidence do not apply to victims in civil cases. (For instance, a law enforcement agency might need to get a court order to conduct network monitoring on a target environment, while the owner of that environment—the victim organization—is allowed to monitor activity within the environment and present resulting data without permission from the courts.)

If an organization decides to become involved in a civil suit, it must be understood that the organization will be bearing the financial burden: attorneys' and court fees and so forth (sometimes, depending on the case and the jurisdiction, the winning side of a civil case may transfer this burden to the loser, but this is not always true and that cost is only recovered

Regulatory

- PCI DSS
- Sarbanes Oxley
- GLBA
- State and federal laws and regulations specific to cyber security
- GDPR



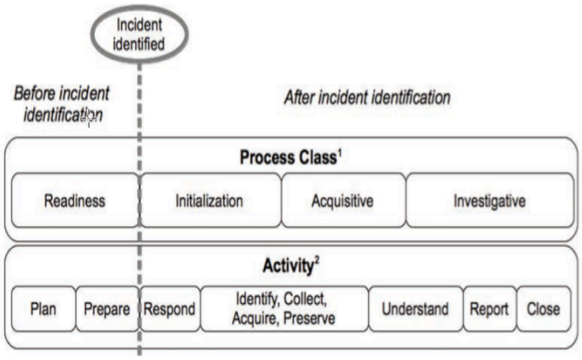
© 2018 Al-Nafi. All Rights Reserved.

Some investigations will be done by or on the behalf of regulatory bodies. When an organization is involved in regulated activity, that activity necessarily is subject to investigation by the pertinent regulator(s).

Regulators may conduct their own investigations, require the target organization to acquire and present information to the regulator, or engage a third party to perform the investigation. In many jurisdictions, regulatory investigation has the force of law, so it will have similar processes to criminal investigations but require a much lower threshold of access (regulators typically do not need warrants, court orders, or subpoenas to gather evidence) and a much lower burden of evidence to make findings (in some jurisdictions, such as in North America, EU, and various other applicable countries).

Industry Standards or investigations

- This is ISO 27043 Information technology — Security techniques — Incident investigation princi

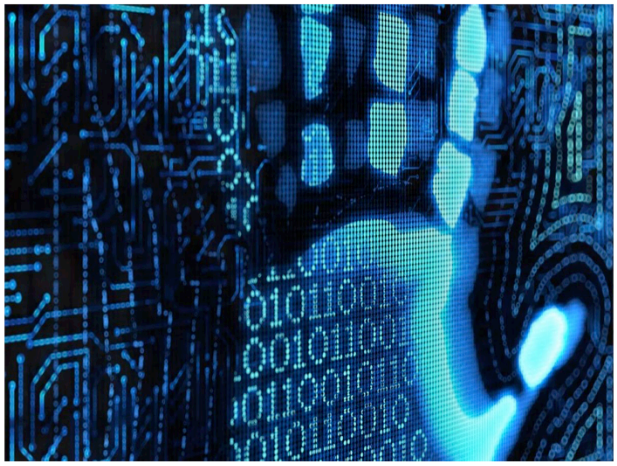


© 2018 Al-Nafi. All Rights Reserved.

There are many industry standards for investigations of all sorts, including IT security and data investigations; applicable standards for a given organization depend on a host of variables, such as geographic region/ jurisdiction, the nature of the data in question, the business of the organization, and so forth. The following is a sample list of standards from around the world; this list is in no way comprehensive or definitive, and the candidate will not be required to memorize these standards for certification purposes. However, many of these standards include common principles and methods of execution, so the candidate is encouraged to review them for insight into professional investigation approaches and expectations.

We will cover in detail the complete process of ISO 27043 standard and the incident investigation process it outlines.

Evidence Collection and Handling



© 2018 Al-Nafi. All Rights Reserved.

ISO 27037 Information technology — Security techniques — Guidelines for identification, collection, acquisition, and preservation of digital evidence we will cover this standard in detail during stage 2 and 3 of the digital forensics and threat hunting.

Evidence Collection and Handling

All material associated with an incident could be pertinent to an investigation and used as evidence. This includes the following:

- Data that may have been compromised.
- Systems (hardware, software, and media) that may have been compromised.
- Data about the incident (all monitoring data from assets reviewing the data/systems that may have been compromised).
- Information from people with knowledge of the incident.
- Information about the incident scene. With an IT-based incident, the incident scene can actually involve many geophysical locations and jurisdictions, including the site where the compromised systems/data resides, the location of the intruder (if unauthorized intrusion was an element of the incident), and any locations between the compromised systems and the intruder where resources were used to aid the intruder.
- There are many sources and forms of evidence, and it all needs to be collected, tracked, and maintained carefully. These are some common practices for handling evidence the security professional should be aware of:
- Maintain a chain of custody. Evidence needs to be handled and maintained in a secure fashion, from the time it is collected until it is presented (usually, to a court). The chain of

Reporting and Documentation

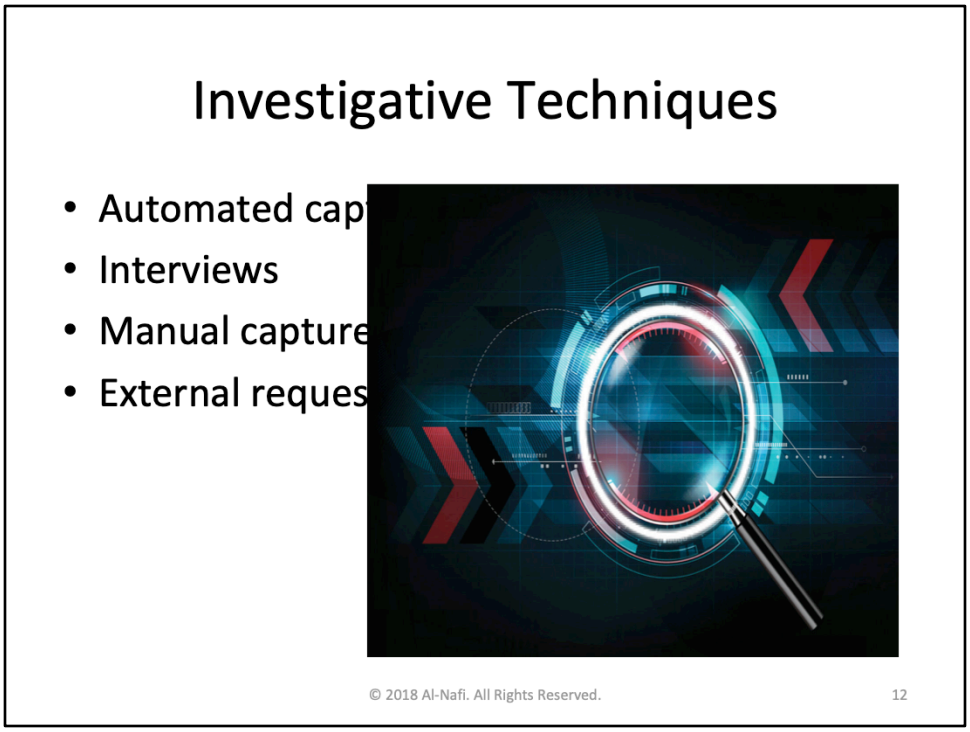
- Admissibility
- Accuracy
- Comprehensibility
- Objectivity

© 2018 Al-Nafi. All Rights Reserved.

Application of this International Standard requires compliance with national laws, rules and regulations. It should not replace specific legal requirements of any jurisdiction. Instead, it may serve as a practical guideline for any DEFR(Digital Evidence First Responder) or DES (Digital Evidence Specialist) in investigations involving potential digital evidence. It does not extend to the analysis of digital evidence and it does not replace jurisdiction-specific requirements that pertain to matters such as admissibility, evidential weighting, relevance and other judicially controlled limitations on the use of potential digital evidence in courts of law. In order to maintain the integrity of the digital evidence, users of the International Standard (ISO) are required to adapt and amend the procedures described in this International Standard in accordance with the specific jurisdiction's legal requirements for evidence.

Although this International Standard does not include forensic readiness, adequate forensic readiness can largely support the identification, collection, acquisition, and preservation process of digital evidence. Forensic readiness is the achievement of an appropriate level of capability by an organization in order for it to be able to identify, collect, acquire, preserve, protect and analyze digital evidence. Whereas the processes and activities described in this International Standard are essentially reactive measures used to investigate an incident after it occurred, forensic readiness is a proactive process of attempting to plan for such events.

- Admissibility: Only evidence that is acceptable to the court may be presented. The court will inform the practitioner if some evidence is unacceptable.
- Accuracy: The evidence should be true and clear.



There are many ways to conduct an investigation and gather evidence. The following is a basic, non-comprehensive list of common evidence gathering techniques and some of the benefits and challenges associated with them.

- Automated capture: The organization's monitoring activity can be used for collecting and analyzing incident data in addition to the goals of detection and performance optimization; this is especially true if the organization has a continuous monitoring program in place. Normal logging can be copied and harvested for evidentiary purposes.

- Interviews: You can solicit information from the people involved with or who have insight into an incident. However, for all organizations other than law enforcement entities, this can pose some legal challenges in many jurisdictions. Some aspects that should be considered when conducting interviews of personnel:

    - Record when possible. In some jurisdictions, recording interviews can be problematic; check your local applicable laws. Be sure to notify the interview subject that the conversation is being recorded (record the notification).
    - Conduct multiparty interviews. Never have a sole interviewer talk to the subject.
    - Ensure preservation of the subject's rights. Comply with all applicable laws regarding interviews. Make sure the subject is aware that they do not have to partake in the interview (even when the choice to refuse an interview

Digital Forensics Tools, Tactics, and Procedures

- Document everything
- Avoid unrecorded/unintended modification
- Collection is a sensitive process
- Not an amateur endeavor



© 2018 Al-Nafi. All Rights Reserved. 13

Documentation is critical when handling digital devices that may contain potential digital evidence. The DEFR (Digital Evidence First Responder) should adhere to the following points during documentation:

Every activity taken should be documented. This is to ensure that no details have been left out during the identification, collection, acquisition and preservation processes. It may also be helpful in a cross-border investigation whereby the potential digital evidence gathered from another part of the globe can be traced accordingly.

The DEFR should be sensitive of the time and date setting if the digital devices are powered on. Compare the time setting with a reliable time source, such as a time that is synchronized with reliable and traceable time source. These time settings should be documented and noted if any differences are present. Some systems require much user interaction in order to get the time and date settings. The DEFR should be cautious not to modify the system. Only properly trained personnel should retrieve these settings.

The DEFR should document anything visible on the digital device screen: active programs and processes, as well the names of open documents. This documentation should include a description of what is visible as some malicious programs may masquerade as well-known software.

Any movement of the digital devices should be documented in accordance with local requirement.

Intrusion Detection and Prevention

- Intrusion detection system (IDS)
- Intrusion prevention system (IPS)

© 2018 Al-Nafi. All Rights Reserved.

This topic was covered in detail in the previous domains:

Here definitions are covered at a high level.

Intrusion detection system (IDS): A solution that monitors the environment and automatically recognizes malicious attempts to gain unauthorized access. The IDS will alert someone within the organization (usually someone in the security office or the IT department) for analysis and follow-up action.

Intrusion prevention system (IPS): A solution that monitors the environment and automatically takes action when it recognizes malicious attempts to gain unauthorized access. It will also typically notify someone within the organization that action has been taken.

Security Information and Event Management (SIEM)

- Aggregatio
- Normaliza
- Correlatio
- Secure sto
- Analysis
- Reporting



© 2018 Al-Nafi. All Rights Reserved. 15

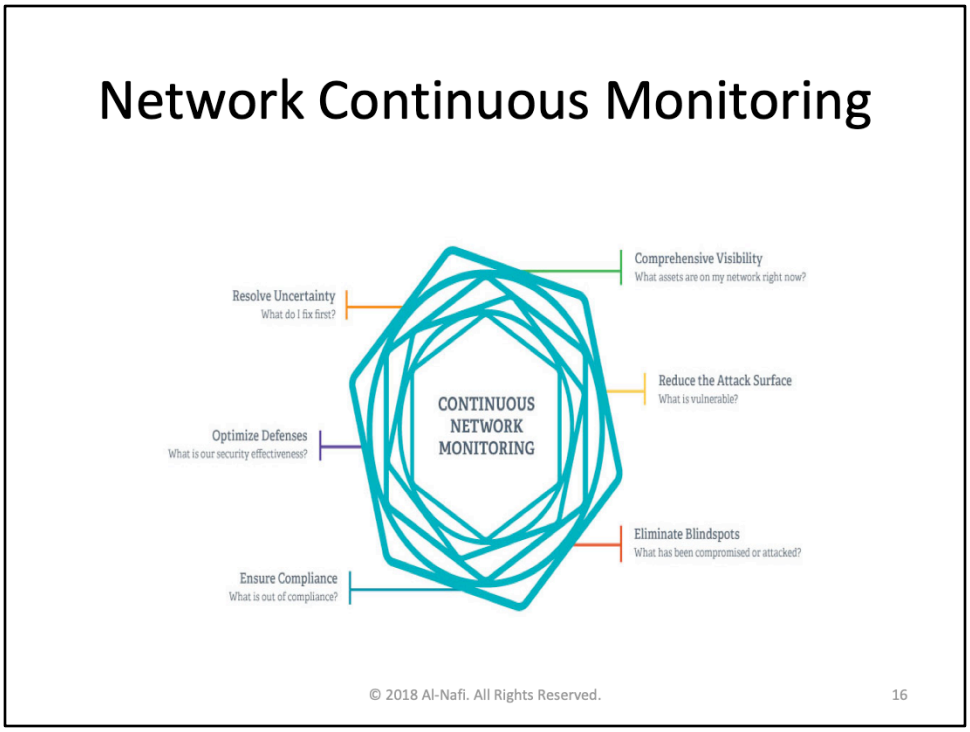
This will be covered in a lot of detail in ISO 27001, PCI DSS and stage 2 courses of CODS.

The current trend in security management involves the use of tools that collect information about the IT environment from many disparate sources to better examine the overall security of the organization and streamline security efforts. These tools are generally known as SIEM solutions.

NOTE: There is no formal industry standard defining SIEM solutions, their function, and their implementation. “SIEM” is a marketing term used by vendors to describe tools that offer some common functions (described in this section of the module). Practitioners should be aware that similar tools offering
the same functionality may be termed “SEIM,” and many tools that were previously called “SEM” or “SIM” may offer the same types of services.

Aggregation: The SIEM tool gathers information from across the environment. This offers a centralized repository of security data and allows analysts to have a single interface with which to perform their duties. The SIEM might gather
log data from:

- Firewalls
- IDS/IPS systems
- IT performance monitoring tools
- Network devices (routers/switches/gateways)
- Individual hosts/endpoints



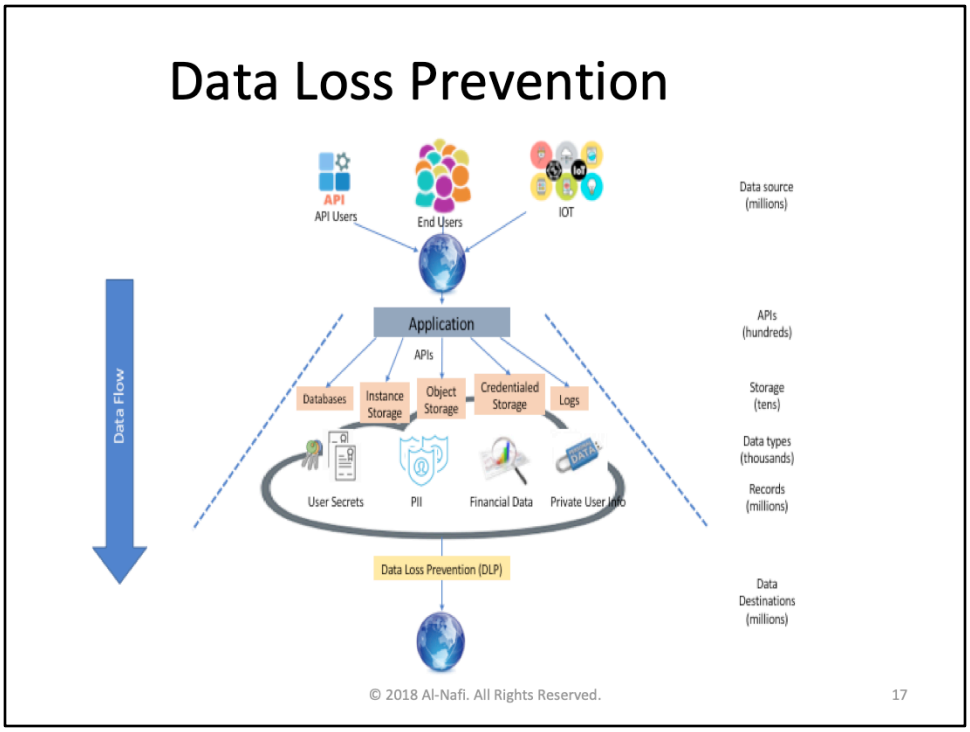
Ingress Monitoring

Ingress monitoring refers to surveillance and assessment of all inbound communications traffic and access attempts. Devices and tools that offer logging and alerting opportunities for ingress monitoring include the following:

- Firewalls
- Gateways
- Remote authentication servers
- IDS/IPS tools
- SIEM solutions
- Anti-malware solutions

Egress Monitoring

Egress monitoring is used to regulate data leaving the organization's IT environment. The term currently used in conjunction with this effort is "DLP"; a marketing descriptor without standard definition, it is often referred to as "data leak protection" or "data loss protection," or some combination of those words. For purposes of addressing this topic, the term DLP will be used synonymously with egress monitoring.



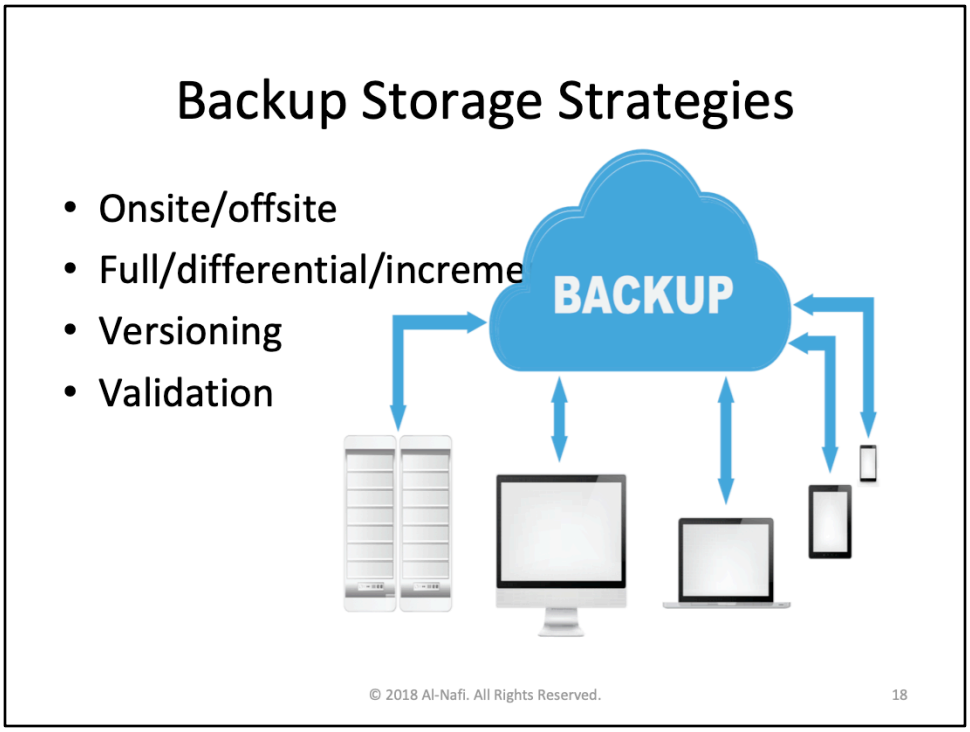
DLP tools function by comparing data leaving the control of the organization against a rule set to determine whether that action is allowed. The DLP rule set can be defined by the following:

Signature: Particular types of data might conform to certain strings that are readily identifiable and can, therefore, be recognized by the tool. For instance, a DLP set to prevent the egress of credit card information might be taught to search for and sequester any 15–20 string of numeric characters.

Pattern matching: The DLP might be conditioned to look for two-word strings where each word starts with one uppercase character and the rest are lowercase; in this way, the DLP might restrict the export of individual
names. This might also be done for the frequency of a given word/words in the context of a page or throughout a document to prevent the egress of proprietary or confidential information.

Labeling: Sensitive assets within the environment might be tagged with specific labels that will be recognized by the DLP tool. For instance, an organization trying to protect proprietary information might embed labels such as “copyright,” “proprietary,” or “confidential” in data assets that should not be shared outside the organization.

For DLP solutions to function properly, they usually need to be deployed in conjunction with



Backup Storage Strategies

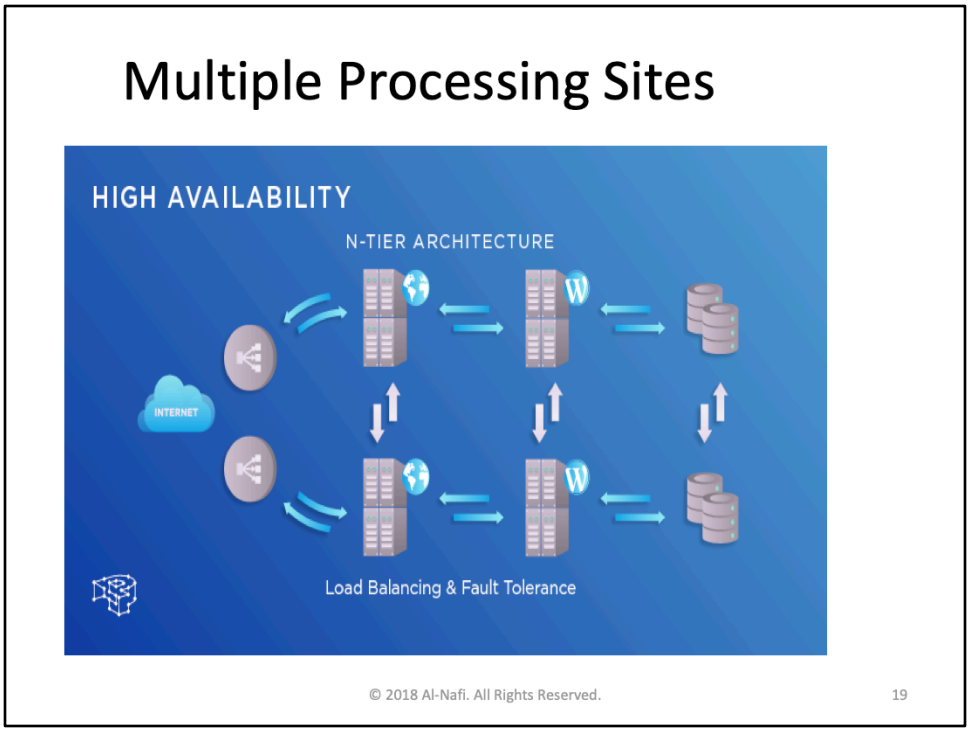
Accurate and comprehensive backups are instrumental to facilitating BCDR efforts; this is an essential aspect of the availability facet of the CIA Triad. Some backup concepts the candidate should be familiar with:

Onsite/offsite: There is a risk/benefit tradeoff to deciding the location of the organization's backups.

o Onsite: The organization has full control (and responsibility) of the stored data. Cost may be proportionally higher for the organization, depending on the organization's core competencies and type of business. (Example: a small or midsize organization might not have the data center capacity and skillset internally to support thorough secure backups.)

o Offsite: The data is exposed to additional risk while it is moved from the organization's environment to the external environment (in transit). The organization loses some control of the security governance and controls used to store the data. Cost may be lower or higher than the onsite option, depending on the nature of the organization and the options offered by the provider. A provider with the sole focus on secure data storage may be able to scale services such that secure storage is much more affordable for its clientele, where the same service would be cost-prohibitive for each individual client.

Full/differential/incremental: The amount of data backed up at any given time can vary



Some organizations that seek to minimize downtime and enhance BCDR capabilities utilize multiple processing sites to obviate the effects of an impact to any single site.

Organizations with extreme sensitivity to downtime—medical providers, military/intelligence agencies, high-volume online retailers, utilities—have a greater need to ensure BCDR capabilities are comprehensive and effective. Here are some techniques for facilitating this practice:
Sufficient spare components: An organization seeking high availability needs to have sufficient components in inventory to replace/repair any affected elements of the environment (or at least those components supporting the critical path). This is a security concern addressed by logistics and budgeting; having too many spares on hand is an expensive proposition and can negatively impact the organization financially just as much as an outage might.

Clustering: Systems can be combined to provide constant full capacity to the organization when one system/element goes down; this is referred to as “clustering” (storage, processing, and network systems can all be clustered). This can be viewed as duplication/replication of the systems in the cluster, and the cluster can enhance normal production through load balancing or merely serve as additional capacity for contingency operations or when widespread temporary scaling is necessary. Common modes of clustering include “active-active” (where all systems in the cluster operate in normal production, each handling a portion of the operational load) and “active-passive” (where at

RAID Types

RAID level	Min disks	Available storage capacity (%)	Write penalty	Protection
1	2	50	2	Mirror
1+0	4	50	2	Mirror
3	3	[(n-1)/n]*100	4	Parity (Supports single disk failure)
5	3	[(n-1)/n]*100	4	Parity (Supports single disk failure)
6	4	[(n-2)/n]*100	6	Parity (Supports two disk failures)

© 2018 Al-Nafi. All Rights Reserved.

RAID: An organization can use a RAID (sometimes repetitively referred to as a "RAID array," or defined as a "redundant array of independent disks") to enhance availability and diminish the risk of downtime due to failure of a single storage component. A RAID setup entails virtualizing a storage volume across several physical disks so that an entire data set is not lost if a single drive fails. The technique of writing a data set across multiple drives is known as striping, and some RAID configurations also use a mechanism known as parity bits to allow recovery of the full data set if one drive fails (the striped data from adjacent drives, combined with the parity bits can fill in the missing data). There are many RAID configurations, and the candidate should be familiar with each:

- RAID: Not actually a redundancy configuration, as the array has no parity bits; this configuration is used for optimizing speed and performance.
- RAID 1: Another method that does not typically use parity bits (and RAID 1 does not even use striping); instead, the data is fully duplicated across multiple drives so that any part of the data set can be recovered if a single drive fails. This can be costly but also serves as a backup for the production data.
- RAID 2: A legacy technique not currently in wide use.
- RAID 3 and 4: Data is striped across multiple drives, and a distinct drive is used to store parity information. RAID 3 stripes data at the byte level; RAID 4 at the block level. These RAID configurations may not be optimum for organizations seeking high availability environments, as the parity drive in each represents a potential single point of failure.
- RAID 5: Both the data and the parity bits are striped across multiple disks; provides high availability.

BCP through ISO 22301 eyes



© 2018 Al-Nafi. All Rights Reserved.

ISO 22031 BCMS main stages

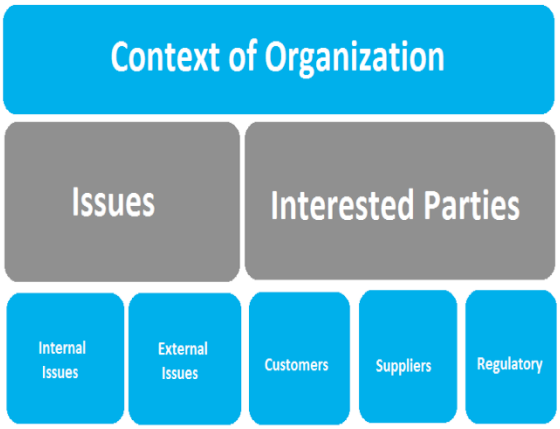
The key areas to focus on are:

- Context of the organization
- Leadership
- Planning
- Support
- Operation
- Performance evaluation
- Improvement

© 2018 Al-Nafi. All Rights Reserved. 22

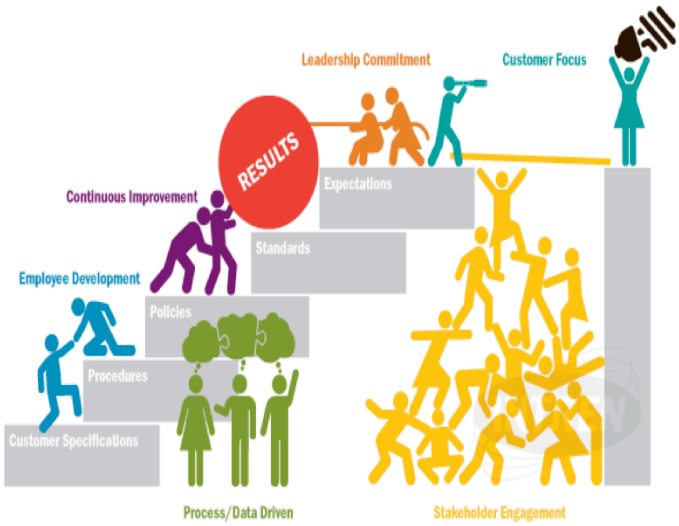
We will cover the ISO 22301 in more details as a new course for ISO 22301 is up the horizon delivered by our Chief Trainer Muhammad Faisal.

What is Context of the organization?



© 2018 Al-Nafi. All Rights Reserved.

Leadership



© 2018 Al-Nafi. All Rights Reserved.

Planning



© 2018 Al-Nafi. All Rights Reserved.

Support



© 2018 Al-Nafi. All Rights Reserved.

Operations



© 2018 Al-Nafi. All Rights Reserved.

Performance evaluation



© 2018 Al-Nafi. All Rights Reserved.

Improvement



© 2018 Al-Nafi. All Rights Reserved.

Types of BCP exercises

- Read through/ table top
- walk through
- Simulation
- Parallel
- Full interruption

© 2018 Al-Nafi. All Rights Reserved.

Read through/ table top



© 2018 Al-Nafi. All Rights Reserved. 31

Reference
https://www.drj.com/pre-2006/winter-2000/business-continuity-planning-tabletop-exercise-white-paper.html

BUSINESS CONTINUITY PLANNING TABLETOP EXERCISE WHITE PAPER
PURPOSE

The purpose of business continuity planning (BCP) tabletop exercising is to demonstrate to management the ability of one or more critical business processes to continue functionality, within the required time frame, following an interruption.

OBJECTIVES

The approach to completing the BCP Tabletop Exercise is to first agree with business process owners and managers on the scope and objectives of the exercise. Facilitated sessions are then planned for the execution of the tabletop exercise. At a high level, the planning and execution of these sessions should include:
Selection of relevant scenarios for the tabletop exercise
Identification, notification and scheduling of appropriate personnel
A facilitated walk-through of the scenario, along with discussions on Business Continuity Plan actions and responsibilities
Capture of tabletop exercise notes, including issues and areas for changes/additions to the BCP documents

walk through



© 2018 Al-Nafi. All Rights Reserved.

Reference
https://www.onsolve.com/blog/how-to-test-your-bc-plan-with-a-structured-walk-through-test/

How to test your BC plan with a structured walk-through test
Tags
Business Continuity Plan Disaster Preparedness Operations Team Building
The structured walk-through test is usually performed with a single team. A version of the test can be performed with team leaders to exercise coordination between teams.

Participants

Business recovery coordinator
Team leaders, customers and alternates
Facilitator
Other personnel as determined necessary

Procedures

Facilitator

- Be sure that the plan, including exhibits, has been distributed to each participant and has been updated before the exercise
- Meet with all participants to explain the purpose and scope of the test and explain the sections of the plan to be exercised
- Describe the disaster scenario (situation) to be used for the exercise backdrop, including:

Simulation BCP



© 2018 Al-Nafi. All Rights Reserved.

Reference
https://smallbusiness.chron.com/conduct-testing-business-continuity-plan-4526.html

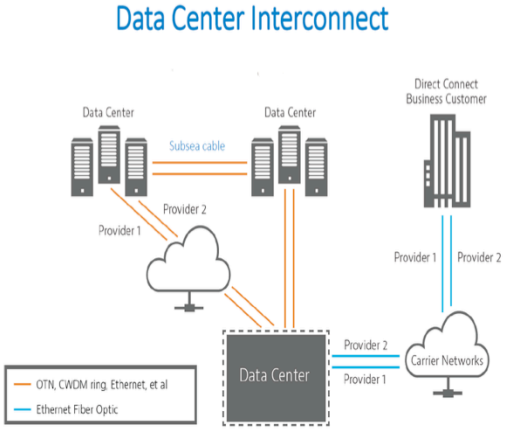
It is important for your firm to have a business continuity plan because in the event of a disaster that causes a business shutdown--a fire or flood for example--you'll be able to minimize losses, down times and the impact on your customers. Once you have developed your business continuity plan, or BCP, it is just as important to test your plan. Testing verifies the effectiveness of your plan, trains plan participants on what to do in a real scenario and identifies areas where the plan needs to be strengthened.

1. Conduct a plan review at least quarterly. Gather your team of key business continuity plan participants--division leaders or department heads--regularly to review the business continuity plan. Discuss the elements of the plan with a focus on the discovery of any areas where the plan can be strengthened. Train new managers regarding the plan and incorporate any new feedback.

2. Conduct disaster role-playing ("table-top") sessions that allow plan participants to "walk through" the facets of the BCP, gaining familiarity with their responsibilities given a specific emergency scenario(s). Conduct the dry-run training to document errors and identify inconsistencies for correction and improvements. Schedule at least two to three of these sessions each year.

3. Perform a simulation of a possible disaster scenario. Include business leaders, partners, vendors, management and staff in the BCP test simulation. Test data recovery, staff safety, asset management, leadership response, relocation protocols and loss recovery procedures.

Parallel BCP



© 2018 Al-Nafi. All Rights Reserved.

Reference https://www.mha-it.com/2016/11/02/disaster-recovery-testing/

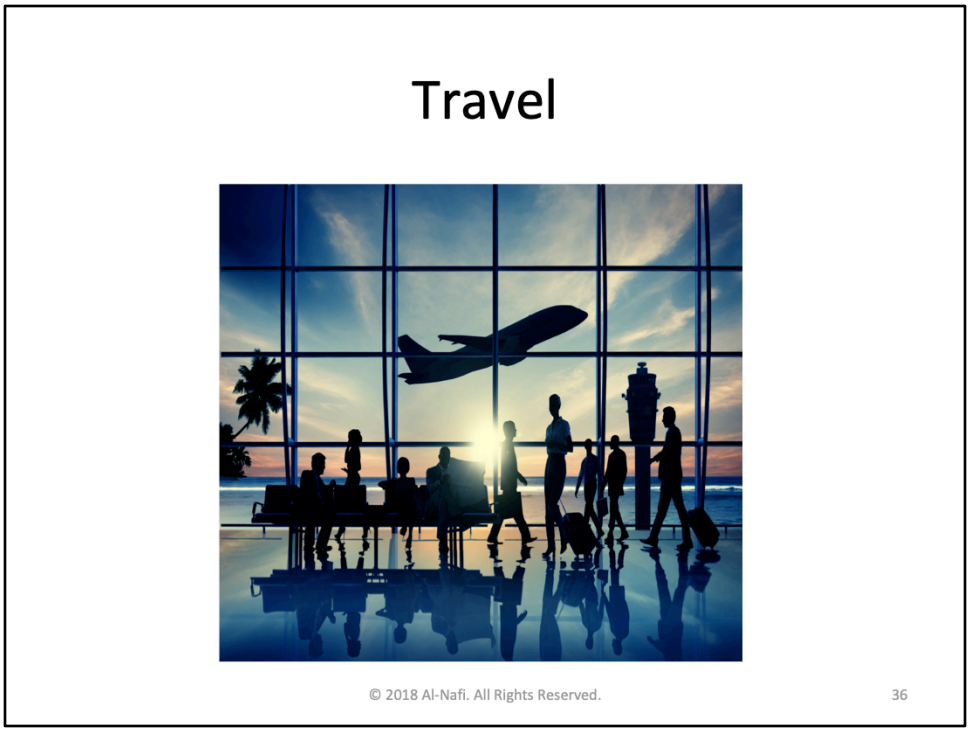
Functional Exercise, Drill or Parallel Test: Involves the actual mobilization of personnel to other sites in an attempt to establish communications and perform processing as set forth in the plans.For Business Continuity, this typically involves determining if employees can actually deploy the procedures defined in the Business Continuity plan.
For Disaster Recovery plans, the goal is to determine whether critical systems can be recovered at the alternate processing site.
Once the individual Business Continuity and Disaster Recovery functional tests are successful, a parallel test for both may be conducted where the business functions relocate to an alternate site and use the recovered systems and applications.

Full interruption



© 2018 Al-Nafi. All Rights Reserved. 35

Full interruptions: The most comprehensive type of testing. In a full-scale test, a real-life situation is simulated as closely as possible. Comprehensive planning is a prerequisite to this type of test to ensure that business operations are not negatively affected. The exercise provides proof of the entire integration of the business continuity plans, relocation plans, and technical recovery plans. This type of exercise should only be attempted once the exercises described above have been successfully completed and the organization is comfortable with the functional capability of the recovery strategies.



Security concerns and risks differ depending on location; the organization should take this into account when personnel are required to work outside the organization's control (that is, everywhere but inside the organization's facilities/campus). Some security aspects to consider when personnel are traveling/ working remotely:

Encryption: Devices and data that are physically moved to any location outside the organization's control can benefit from the additional protection of encryption; this can protect the organization from loss of data due to interception in transit or physical theft/loss of a device. However, if personnel are traveling internationally, encryption options may be limited by law in some jurisdictions.

Secure remote access: If personnel are going to connect to the organization's environment from off-site facilities, the organization needs to create a secure mechanism for doing.

Additional jurisdictional concerns: Data moved across borders may be subject to different statutory/contractual regulation.

Personnel protection: Personnel need to be protected according to the specific security conditions of geographical areas where they may be traveling. The organization should provide location specific orientation material for travelers, additional personal training, medical/life insurance, and physical protection elements as needed.

Condition monitoring: When personnel are traveling, someone remaining at the

Security Training and Awareness

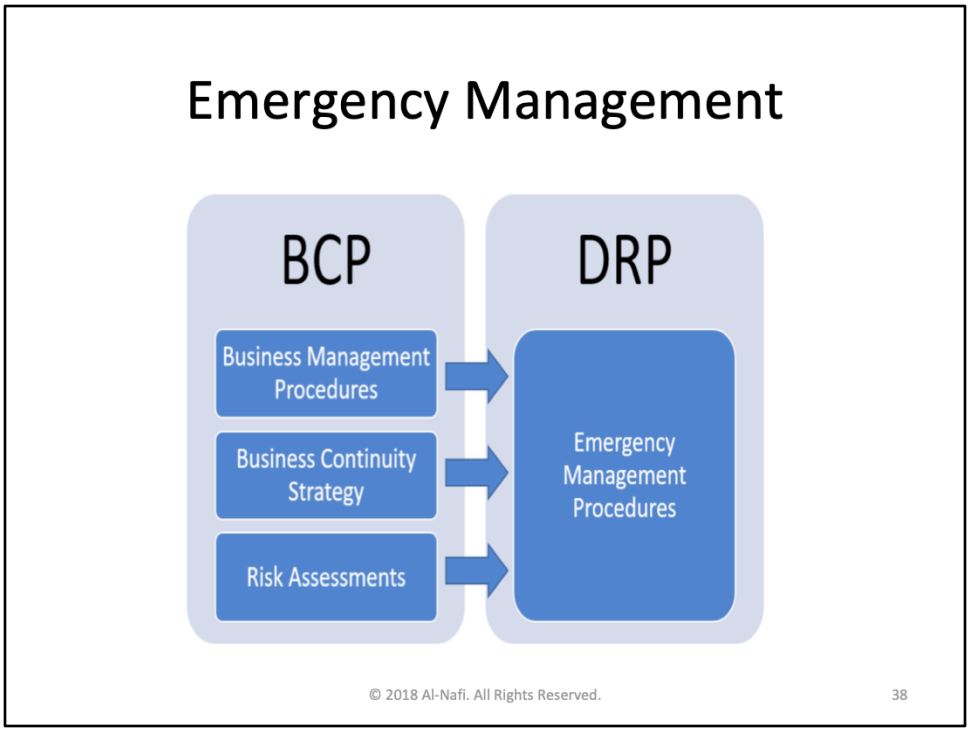


© 2018 Al-Nafi. All Rights Reserved.

Health and human safety is the paramount concern of all security efforts; ensuring personnel are properly trained and aware of safety and security threats and risks is essential.

This effort should include the following:

- Location-specific orientation, training, and awareness for travelers (see previous topic in this module).
- Emergency procedures (see next topic in this module).
- Incident reporting procedures (see Module 5 in this domain).
- Users' role(s) in incident detection and response.
- How to recognize attack attempts that directly target individual users (phishing, social engineering, etc.).



All emergency/BCDR planning should take into account personnel safety as the highest priority. Elements of the security program specific to personnel safety should include the following:

- Fire detection/suppression systems designed to protect human health and safety first and foremost. All egress paths from the facility should be equipped with deluge systems. Fire marshals (and alternates) should be assigned per workspace and fully trained and practiced.

- Evacuation of personnel should be practiced on a regular basis; all personnel should be aware of emergency exits and procedures.

- Coordination with all applicable external entities (law enforcement, fire department, medical response, etc.) should be performed prior to any actual event so that ready communication and familiarity is established.

- The organization's BCDR team needs to consider all localized threats (natural disaster/ weather applicable to the particular location, etc.) when making the response plan and in designing the thresholds for initiating the response.

- Asset protection activities must *not* put personnel in jeopardy.

- If the organization's BCDR response includes relocating critical personnel to a

Duress



© 2018 Al-Nafi. All Rights Reserved. 39

Personnel should have a means to report to the organization if they are ever put under duress (threatened or hindered in movement). This is especially true for travelers, senior management, and critical personnel, all who may be subject to crimes that target those roles (kidnapping, terror attacks, etc.).

Personnel should be able to convey duress situations in a subtle manner (that is, with code words other than, “I’m under duress”) that can be worked into normal communications and can be remember while the subject is under extreme stress. Duress codes should be able to be conveyed by several methods of communication (verbal and otherwise). Personnel receiving duress codes should have training and practice in the actions to undertake in those circumstances.

Duress codes should change on a regular basis, but if personnel convey expired codes, a response process should still be initiated.

جزاك الله

To ask questions, Join the Al Nafi Official Group

https://www.facebook.com/groups/alnafi/

(This group is only for members to ask questions)

© Abdulhadi Al Nafi. All rights reserved.